

ISO/IEC 42001:2023

SISTEMA DE GESTIÓN DE IA

Manual de Gestor Práctico de AIMS y Analista Junior

Qué hace este manual: Explica cómo establecer, implementar, operar, auditar, certificar y mejorar un sistema de gestión de IA. Desglosa las Cláusulas 4–10, los nueve grupos de control del Anexo A, la evaluación de riesgos e impacto, la Declaración de Aplicabilidad, la certificación, la evidencia, las herramientas, las decisiones de los directivos y el trabajo de analistas junior.

Alberto (Al) Leiva

Primera edición • julio de 2026

Prefacio

ISO/IEC 42001 ayuda a las organizaciones a gobernar la IA mediante un sistema de gestión a nivel organizacional. No certifica que todos los resultados sean correctos ni que todos los sistemas de IA sean seguros. Requiere liderazgo, contexto, planificación basada en riesgos, recursos, controles operativos, evaluación del rendimiento, acciones correctivas y mejora continua en torno al desarrollo, la provisión o el uso responsable de sistemas de IA.

Este manual explica los conceptos en el idioma original y no reproduce el estándar protegido por derechos de autor. Obtenga una copia autorizada de ISO/IEC 42001:2023 y de cualquier norma utilizada para su implementación o auditoría. Las certificaciones, leyes, deberes sectoriales, contratos y riesgos técnicos deben evaluarse en función del alcance real y de los hechos de la organización.

Nota de información actualizada: Verificada el 14 de julio de 2026. ISO/IEC 42001:2023 sigue siendo la norma publicada de requisitos de AIMS. ISO/IEC 42005:2025 proporciona orientación para la evaluación del impacto de los sistemas de IA. ISO/IEC 42006:2025 establece requisitos para los organismos que auditan y certifican AIMS. La norma ISO 19011:2026 es la directriz actual para la auditoría del sistema de gestión. ISO/IEC 42003 y 42007 siguen en desarrollo y no se consideran requisitos aquí.

Cómo usar este manual

- Líderes y gestores de AIMS: empieza por los capítulos 1–10, 16–20 y 29–31.
- Implementadores y equipos de GRC: estudien en orden y utilicen cada plantilla del Capítulo 32.
- IA, datos, producto, seguridad, privacidad y equipos legales: centrarse en los capítulos 6–15 y 20–28.
- Auditores internos: céntrate en los capítulos 16–20 y 29, y luego practica el laboratorio en el capítulo 31.
- Analistas juniors: aprended la cláusula de intención, presentad pruebas, redactad conclusiones y nunca reclaméis la certificación o autoridad de auditoría que no tengáis.

Índice

Este archivo contiene un índice nativo de Word auténtico, además de una guía permanente de capítulos numerada por página.

Prefacio	2
Cómo usar este manual	2
Índice	3
Guía de capítulos	7
1. ISO/IEC 42001 y el Sistema de Gestión de IA	8
1.1 Lo que la certificación no prueba	8
2. Arquitectura AIMS y el ciclo de planificar-hacer-revisar-actuar	9
2.1 Integración con sistemas existentes	9
3. Aplicabilidad, roles organizativos y hoja de ruta de implementación	10
3.1 Hoja de ruta de implementación	10
4. Cláusula 4: Contexto de la Organización	12
4.1 Cuestiones internas y externas	12
4.2 Partes interesadas y requisitos	12
4.3 Declaración de alcance	12
4.4 Procesos AIMS	12
5. Cláusula 5: Liderazgo	13
5.1 Demuestra de liderazgo	13
5.2 Política de IA	13
5.3 Roles, responsabilidades, autoridades	13
6. Cláusula 6.1: Acciones para abordar riesgos y oportunidades	14
6.1 Insumos de planificación	14
6.1.1 Acciones de riesgo y oportunidad	14
7. Cláusula 6.1.2: Evaluación de riesgos de IA	15
7.1 Método de riesgo	15
8. Cláusula 6.1.3: Tratamiento de Riesgo de IA y la Declaración de Aplicabilidad	16
8.1 Proceso de tratamiento	16
8.2 Enunciado de campos de aplicabilidad	16
9. Cláusula 6.1.4: Evaluación del Impacto del Sistema de IA	17
9.1 Proceso de evaluación de impacto	17
9.2 Evaluación de riesgos frente a evaluación de impacto	18

10. Cláusulas 6.2 y 6.3: Objetivos y cambios en la planificación	19
10.1 Récord objetivo	19
10.2 Cambios en la planificación de AIMS	19
11. Cláusula 7.1: Recursos	20
11.1 Decisiones sobre recursos	20
12. Cláusulas 7.2–7.4: Competencia, Conciencia y Comunicación	21
12.1 Competencia	21
12.2 Concienciación	21
12.3 Plan de comunicación	21
13. Cláusula 7.5: Información documentada	22
13.1 Ciclo de vida del control de documentos	22
14. Cláusula 8.1: Planificación y Control Operativo	23
14.1 Control operativo	23
15. Cláusulas 8.2–8.4: Riesgo Operativo, Tratamiento y Evaluación de Impacto	24
15.1 Disparadores operativos	24
15.2 Evidencia operativa	24
16. Cláusula 9.1: Monitorización, Medición, Análisis y Evaluación	25
16.1 Diseño de medidas	25
17. Cláusula 9.2: Auditoría interna	26
17.1 Programa de auditoría	26
17.2 Documento de trabajo de auditoría	26
18. Cláusula 9.3: Revisión de la Dirección	27
18.1 Entradas	27
18.2 Salidas	27
19. Cláusula 10: No conformidad, acciones correctivas y mejora continua	28
19.1 Método de acción correctiva	28
20. Anexos A–D y la Declaración de Aplicabilidad	29
20.1 Cómo funcionan los anexos	29
21. Anexo A.2: Políticas relacionadas con la IA	30
21.1 Implementación de control	30
22. Anexo A.3: Organización interna	31
22.1 Roles y responsabilidades	31
22.2 Preocupaciones sobre la notificación	31
23. Anexo A.4: Recursos para sistemas de IA	32

23.1 Flujo de trabajo de documentación de recursos.....	32
24. Anexo A.5 e ISO/IEC 42005: Evaluación de Impacto del Sistema de IA	33
24.1 Cuatro resultados de control	33
24.2 Controles de calidad de la evaluación	33
25. Anexo A.6: Ciclo de vida del sistema de IA.....	34
25.1 Cambio y jubilación	34
26. Anexo A.7: Datos para sistemas de IA	35
26.1 Controles de datos	35
27. Anexo A.8: Información para las Partes Interesadas	37
Paquete informativo 27.1	37
27.2 Informes y incidentes externos	37
28. Anexos A.9 y A.10: Uso responsable, proveedores y clientes.....	39
28.1 Uso responsable	39
28.2 Terceros y clientes	39
29. Certificación, ISO/IEC 42006:2025, y Preparación para la Auditoría	41
29.1 Camino de certificación.....	41
29.2 Importancia de ISO/IEC 42006:2025.....	41
29.3 Preparación para auditoría sin teatro	41
30. Herramientas de Evidencia de Código Abierto de AIMS y Garantía de IA	43
30,1 MLflow	43
30.2 DVC	43
30.3 OpenLineage.....	44
30.4 OpenMetadata	44
30.5 Grandes Esperanzas.....	44
30.6 Evidentemente.....	44
30.7 Deepchecks	45
30,8 Giskard	45
30.9 Promptfoo.....	45
30.10 Garak.....	45
30.11 PyRIT.....	45
30.12 Inspeccionar IA	46
30.13 Presidio.....	46
30.14 ModelScan	46
30.15 CycloneDX	46

30.16 Agente de Políticas Abiertas.....	47
30.17 DefectDojo.....	47
30.18 Langfuse	47
31. Manual de Jefe y Analista Junior, Laboratorio y Entrevistas.....	48
31.1 Preguntas sobre el gerente	48
31.2 Trabajo como analista junior	48
31.3 Laboratorio ficticio	49
31.4 Plan de treinta días.....	49
31.5 ¿Qué es ISO/IEC 42001?	49
31.6 ¿Qué es un AIMS?.....	50
31.7 ¿Son obligatorios todos los controles del Anexo A?.....	50
31.8 ¿Evaluación de riesgo frente a impacto?.....	50
31.9 ¿Qué es la Declaración de Aplicabilidad?	50
¿31.10 Fase 1 frente a Fase 2?.....	50
31.11 ¿Qué es una no conformidad?	50
31.12 ¿Cómo demuestran las herramientas la conformidad?	50
31.13 ¿Cómo se prueba una acción correctiva?	50
31.14 ¿Qué hace a un analista junior fuerte?.....	50
32. Plantillas, glosario, índice y referencias oficiales.....	51
32.1 Registro de alcance y contexto de AIMS.....	51
32.2 Historial de riesgo y tratamiento de IA	51
32.3 Declaración de Aplicabilidad	51
32.4 Evaluación del impacto en sistemas de IA	51
32.5 Documento de trabajo de auditoría interna.....	52
32.6 Historial de revisión de la dirección.....	52
32.7 Glosario	52
32.8 Índice temático	53
32.9 Referencias oficiales	53

Guía de capítulos

Capítulo	Título	Empieza en la página
1	ISO/IEC 42001 y el Sistema de Gestión de IA	5
2	Arquitectura AIMS y el ciclo de Plan-Hacer-Revisar-Actar	6
3	Aplicabilidad, roles organizativos y hoja de ruta de implementación	7
4	Cláusula 4: Contexto de la Organización	9
5	Cláusula 5: Liderazgo	10
6	Cláusula 6.1: Acciones para abordar riesgos y oportunidades	11
7	Cláusula 6.1.2: Evaluación de riesgos de IA	12
8	Cláusula 6.1.3: Tratamiento de Riesgo por IA y la Declaración de Aplicabilidad	14
9	Cláusula 6.1.4: Evaluación del impacto del sistema de IA	15
10	Cláusula 6.2 y 6.3: Objetivos y cambios en la planificación	17
11	Cláusula 7.1: Recursos	18
12	Cláusulas 7.2–7.4: Competencia, Conciencia y Comunicación	19
13	Cláusula 7.5: Información documentada	20
14	Cláusula 8.1: Planificación y Control Operativo	21
15	Cláusulas 8.2–8.4: Riesgo Operativo, Tratamiento y Evaluación de Impacto	22
16	Cláusula 9.1: Monitorización, Medición, Análisis y Evaluación	23
17	Cláusula 9.2: Auditoría interna	24
18	Cláusula 9.3: Revisión de la Dirección	26
19	Cláusula 10: No conformidad, acciones correctivas y mejora continua	27
20	Anexos A–D y la Declaración de Aplicabilidad	28
21	Anexo A.2: Políticas relacionadas con la IA	29
22	Anexo A.3: Organización interna	30
23	Anexo A.4: Recursos para sistemas de IA	31
24	Anexo A.5 e ISO/IEC 42005: Evaluación del Impacto del Sistema de IA	32
25	Anexo A.6: Ciclo de vida de los sistemas de IA	33
26	Anexo A.7: Datos para sistemas de IA	34
27	Anexo A.8: Información para las Partes Interesadas	36
28	Anexos A.9 y A.10: Uso responsable, proveedores y clientes	38
29	Certificación, ISO/IEC 42006:2025 y Preparación para la Auditoría	40
30	Herramientas de Evidencia y Garantía de IA de AIMS de código abierto	42
31	Manual de Jefe y Analista Junior, Laboratorio y Entrevistas	47
32	Plantillas, glosario, índice y referencias oficiales	51

1. ISO/IEC 42001 y el Sistema de Gestión de IA

ISO/IEC 42001 especifica requisitos para que una organización establezca, implemente, mantenga y mejore continuamente un sistema de gestión de IA.

Concepto	Significado sencillo	Pregunta sobre la evidencia
OBJETIVOS	Políticas, objetivos, procesos, roles, controles y registros interrelacionados para la IA responsable	¿El sistema opera dentro del ámbito definido?
Papel organizativo	Desarrollador/proveedor, desplegador/usuario, proveedor, cliente o varios roles	¿Qué responsabilidades están controladas?
Sistema de IA	Personas, datos, modelos, software, infraestructura, procesos e interfaces utilizados para un resultado de IA	¿Cuál es el límite completo?
Conformidad	Los requisitos se cumplen dentro del alcance certificado	¿Qué cláusula, implementación, evidencia y resultado respaldan la afirmación?
Certificación	Evaluación independiente de terceros del AIMS en comparación con ISO/IEC 42001	¿Qué entidad, alcance, estándar, cuerpo, fechas y estatus están certificados?

1.1 Lo que la certificación no prueba

- No garantiza que todos los resultados de la IA sean precisos, imparciales, seguros, legales o explicables.
- No certifica productos de IA individualmente, a menos que el alcance y el esquema AIMS del certificado respalden explícitamente dicha afirmación.
- No sustituye las pruebas de producto, el análisis legal, la evaluación de impacto, los controles de privacidad/seguridad, la validación de dominios ni la supervisión humana.
- No transfiere la responsabilidad de la organización al organismo ni al proveedor certificador.

2. Arquitectura AIMS y el ciclo de planificar-hacer-revisar-actuar

El AIMS sigue la estructura armonizada del sistema de gestión y el ciclo continuo de Planificar-Hacer-Revisar-Actuar.



The AIMS is a living management system, not a one-time certification project

Figura 1. Ciclo AIMS Planificar-Hacer-Revisar-Actuar

Etapa PDCA	Trabajo ISO/IEC 42001	Salida típica
Plan	Contexto, liderazgo, evaluación de riesgos/oportunidades, tratamiento, objetivos, recursos	Alcance, política, métodos, registro de riesgos, proceso de impacto, SoA, objetivos
Do	Competencia, comunicación, documentación, controles operativos, evaluaciones	Procedimientos, registros del sistema, aprobaciones, pruebas de proveedores y del ciclo de vida
Comprobado	Monitorización, medición, análisis, auditoría interna, revisión de la gestión	Métricas, evaluación, informes de auditoría, decisiones de revisión
Ley	No conformidad, corrección, causa raíz, acción correctiva, mejora	Registros de acciones, pruebas de efectividad, riesgos/controles/objetivos actualizados

2.1 Integración con sistemas existentes

- Reutilizar procesos de gobernanza, control documental, riesgos, auditoría, acciones correctivas, proveedores, seguridad, privacidad, calidad y continuidad cuando su alcance y sus controles se ajusten al riesgo de IA.
- Crear adiciones específicas para la IA para la evaluación de impacto, el ciclo de vida de modelos y datos, el uso responsable, la transparencia, la supervisión humana y las responsabilidades a lo largo de la cadena de valor.
- Mantén una fuente de verdad y mapárala a ISO 27001, ISO 9001, privacidad, legal, NIST AI RMF y a las obligaciones sectoriales, en lugar de duplicar registros.

3. Aplicabilidad, roles organizativos y hoja de ruta de implementación

Una implementación útil comienza con el control organizativo, un inventario preciso de IA, roles responsables y una hoja de ruta escalonada.



A defensible scope connects organizational control to real AI systems and obligations

Figura 2. Cadena de construcción de alcance

Función	Responsabilidad principal
Órgano de gobierno / ejecutivos	Supervisión, dirección, recursos, apetito por el riesgo, decisiones materiales
Líder de AIMS	Coordinar el sistema de gestión, el rendimiento, las auditorías, la mejora
Propietario de un sistema empresarial/IA	Propósito, resultado, proceso afectado, riesgo, aprobación, seguimiento
Modelo/datos/producto/ingeniería	Requisitos, diseño, datos, evaluación, despliegue, cambio
Seguridad/privacidad/legal/cumplimiento/protección	Requisitos especializados, revisión, impugnación, incidentes
Responsable de adquisiciones/proveedores	Debida diligencia, asignación, contratos, pruebas, monitorización, salida
Auditoría interna	Evaluación independiente y objetiva sin poseer los controles

3.1 Hoja de ruta de implementación

- Autorizar el programa y obtener los estándares; definir el propósito, el patrocinador, los recursos y la gobernanza.
- Sistemas y roles de IA de inventario; realizar análisis de contexto y de las partes interesadas; redactar el alcance y la política.
- Define riesgo, impacto, tratamiento, SoA, objetivos, documentación, competencia, comunicación y procesos operativos.
- Implementar el Anexo A y controles adicionales según el nivel de riesgo; recoger pruebas durante la operación real.

- Mide el rendimiento; auditoría interna completa y revisión de gestión; corrige las inconformidades y verifica su efectividad.
- Seleccionar un organismo certificador competente; completar las Fases 1 y 2; mantener la vigilancia y mejorar.

4. Cláusula 4: Contexto de la Organización

La cláusula 4 establece por qué existe el AIMS, quién lo importa, qué cubre y cómo interactúan sus procesos.

4.1 Cuestiones internas y externas

- Estrategia, cultura, gobernanza, apetito por el riesgo, recursos, competencia, madurez de datos, arquitectura tecnológica, sistemas de gestión existentes y cambio organizativo.
- Ley, regulación, expectativas sectoriales, contratos, requisitos de los clientes, estándares, confianza pública, preocupaciones sociales, mercados, proveedores, amenazas, cambios tecnológicos y de modelos, y cuestiones relacionadas con el clima cuando sean relevantes para los resultados previstos de GOALS.
- Registra por qué cada problema es relevante, el propietario, el efecto en el AIMS, la respuesta y el desencadenante de la revisión.

4.2 Partes interesadas y requisitos

- Identifica a las personas y grupos afectados por la IA, incluso si no son usuarios ni clientes directos.
- Incluye reguladores, clientes, trabajadores, usuarios, sujetos de datos, proveedores, socios, comunidades, accionistas, auditores, aseguradoras y el público según corresponda.
- Separar las necesidades/expectativas de las obligaciones vinculantes de cumplimiento; registrar la autoridad/fuente, el sistema/proceso, el propietario, la evidencia y la monitorización de cambios.
- Determina qué requisitos abordará la organización mediante el AIMS.

4.3 Declaración de alcance

Elemento de alcance	Claridad requerida
Organización	Entidades jurídicas, unidades de negocio, ubicaciones, funciones
Rol en la IA	Desarrollador/proveedor, desplegador/usuario, servicio/proveedor, combinación
Productos/servicios/procesos	Ofertas habilitadas por IA y usos internos
Tecnología y datos	Sistemas, modelos, entornos, interfaces, conjuntos de datos clave
Límites/dependencias	Servicios compartidos, proveedores, clientes, exclusiones
Justificación	Por qué los límites son válidos y no evitan los requisitos aplicables

4.4 Procesos AIMS

- Define el propósito del proceso, entradas, salidas, secuencia, interacción, propietario, criterios, controles, recursos, registros, medidas, riesgos y mejora.
- Un mapa de procesos debe conectar el inventario, el riesgo, el impacto, el tratamiento, los objetivos, el ciclo de vida, los datos, el proveedor, el uso, la monitorización, los incidentes, la auditoría, la revisión y las acciones correctivas.

5. Cláusula 5: Liderazgo

El liderazgo debe ser responsable de los AIMS, la política, la integración, los recursos, la comunicación, el rendimiento y los roles.

5.1 Demuestra de liderazgo

- Asegurar que los objetivos de AIMS sean compatibles con la estrategia y los compromisos de IA responsable.
- Integrar los requisitos de AIMS en los procesos de negocio, producto, adquisiciones, datos, tecnología, personas, riesgos y cambio.
- Proporcionar personas competentes, tiempo, herramientas, datos, infraestructura, presupuesto, retos independientes y autoridad.
- Comunica que la gestión y conformidad efectivas de la IA son importantes, incluso cuando la presión de entrega entra en conflicto con los controles.
- Revisa el rendimiento y apoya a quienes contribuyen a la mejora o plantean preocupaciones.
- Asegurarse de que se alcancen los resultados esperados en lugar de tratar la certificación como el único resultado.

5.2 Política de IA

- Establecer propósito, principios, compromisos con los requisitos aplicables, IA responsable basada en riesgos, objetivos y mejora continua.
- Ajusta los roles de IA de la organización, el contexto, la cultura, el impacto, el derecho, los productos y el apetito por el riesgo.
- Alinear las políticas de seguridad, privacidad, calidad, datos, ética, recursos humanos, adquisiciones, producto, registros, seguridad e incidentes.
- Aprueba en el nivel adecuado, comunícalo a las personas relevantes, ponlo a disposición cuando corresponda y revísalo en los intervalos planificados y tras el cambio material.

5.3 Roles, responsabilidades, autoridades

- Definir la responsabilidad de los AIMS y la de informar al rendimiento a la alta dirección.
- Asigna propietarios a cada sistema de IA, de riesgo, de impacto, de fuente de datos, de modelo, de proveedor, de control, de métrica, de incidente, de cambio y de acción correctiva.
- Define la autoridad de aprobación y de escalada; previene conflictos en los que el propio equipo crea, valida, acepta y audita riesgos de alto impacto sin un desafío adecuado.

6. Cláusula 6.1: Acciones para abordar riesgos y oportunidades

La planificación convierte el contexto en riesgos gestionados, oportunidades, controles, objetivos y cambios controlados.

6.1 Insumos de planificación

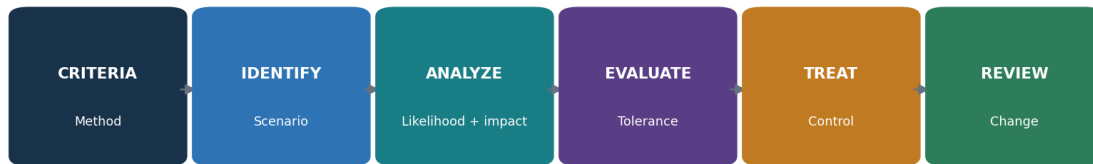
- Contexto y requisitos de las partes interesadas; alcance y procesos de AIMS.
- Inventario de IA, roles del sistema, etapa del ciclo de vida, personas afectadas, datos, modelos, proveedores, integraciones y condiciones de uso.
- Beneficios y oportunidades estratégicas, junto con amenazas, fracasos, daños, incertidumbre y un uso indebido razonablemente previsible.
- Obligaciones legales, regulatorias, contractuales, de seguridad, de privacidad, de calidad, de registros, de accesibilidad, de empleo, de propiedad intelectual, de consumidor y sectoriales aplicables.

6.1.1 Acciones de riesgo y oportunidad

- Planificar acciones proporcionales al efecto en los resultados de GOALS e integrarlas en los procesos, en lugar de mantener solo un registro separado.
- Define la acción, el propietario, el recurso, la fecha, la medida, la evidencia, la dependencia, la decisión residual y la evaluación de la efectividad.
- Las oportunidades pueden incluir una mejor supervisión, calidad de los datos, transparencia, evaluación, competencia, eficiencia, confianza de las partes interesadas e innovación.
- Evitar que los controles previstos generen nuevos riesgos, como supervisión excesiva, avisos inaccesibles o sobrecarga de revisiones.

7. Cláusula 6.1.2: Evaluación de riesgos de IA

El proceso de evaluación de riesgos de IA debe utilizar criterios definidos y repetibles para identificar, analizar, evaluar y priorizar dichos riesgos.



AI risk assessment must be consistent, repeatable, and tied to decisions

Figura 3. Flujo de trabajo de evaluación de riesgos con IA

7.1 Método de riesgo

- Definir el alcance, la unidad de análisis, las categorías de riesgo, las dimensiones de impacto, la verosimilitud, la gravedad, la escala, la duración, la reversibilidad, los grupos afectados, la incertidumbre, la agregación, la tolerancia y la autoridad de decisión.
- Identificar escenarios de riesgo a través del uso previsto, del uso indebido previsible, del fallo, del ataque, de los datos, del modelo, del comportamiento humano, de los proveedores, del medio ambiente, del derecho y del efecto social.
- Analizar el riesgo inherente y los controles existentes con evidencia; distinguir entre riesgo actual, riesgo objetivo y riesgo residual.
- Evalúa según los criterios; prioriza el tratamiento en función de las personas y las consecuencias empresariales, no de una puntuación técnica única.
- Asegurar resultados consistentes, válidos y comparables y conservar la evaluación como información documentada.
- Reevaluar en intervalos planificados y tras cambios materiales, incidentes, nuevos grupos afectados, actualizaciones de modelos/proveedores, deriva, cambios legales o fallos en el control.

Historial de riesgos	Detalle mínimo
Escenario	Causa/actor, condición vulnerable, evento/acción, comportamiento del sistema, parte afectada, consecuencia
Contexto	Uso, personas, geografía, escala, datos, modelo/versión, herramientas, proveedor, suposiciones
Análisis	Probabilidad, dimensiones de impacto, incertidumbre, evidencia, efectividad existente del control
Tratamiento	Evitar/reducir/compartir/aceptar, controles, propietario, fecha, medida, riesgo residual
Decisión	Aprobador autorizado, justificación, condiciones, expiración, monitorización, activador de revisión

8. Cláusula 6.1.3: Tratamiento de Riesgo de IA y la Declaración de Aplicabilidad

El tratamiento de riesgos selecciona los controles, los compara con el Anexo A, produce la Declaración de Aplicabilidad y obtiene la aprobación de riesgo residual.

8.1 Proceso de tratamiento

- Elige opciones de tratamiento: evitar, cambiar/reducir, compartir/transferir, aceptar dentro de la autoridad o realizar un piloto muy limitado para reducir la incertidumbre.
- Determinar los controles necesarios a partir de los requisitos legales y contractuales, de los resultados de riesgo e impacto de la IA, de la arquitectura, de los grupos de interés y de los objetivos.
- Comparar los controles seleccionados con el Anexo A para verificar que no se haya pasado por alto ningún control de referencia relevante.
- Añadir controles más allá del Anexo A cuando sea necesario para la seguridad, la privacidad, la protección, la calidad, la evaluación técnica, la accesibilidad, la resiliencia o las obligaciones sectoriales.
- Crea y aprueba un plan de tratamiento y obtén autorización para el riesgo residual.
- Conserva los resultados y los cambios del tratamiento como información documentada controlada.

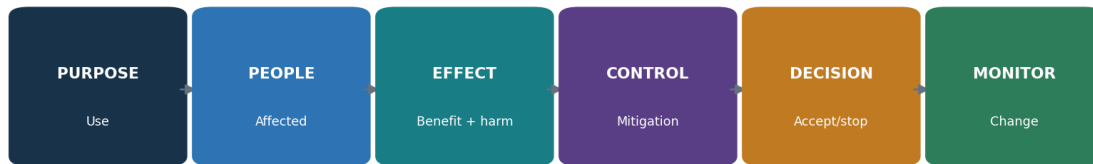
8.2 Enunciado de campos de aplicabilidad

Campo	Propósito
Referencia/título de control	Anexo A o identidad de control adicional
¿Aplicable?	Incluido o excluido para el alcance definido de AIMS
Justificación	Riesgo, obligación, objetivo, arquitectura o motivo de exclusión
Implementación	Política/proceso/sistema y propietario responsable
Estado	Implementado, parcial, planificado, no aplicable
Prueba/prueba	Prueba actual y resultado de efectividad operativa
Dependencias/lagunas	Controles y hallazgos compartidos de proveedores/clientes
Reseña	Última y siguiente revisión y desencadenantes de cambio

Advertencia de SoA: La Declaración de Aplicabilidad no es una lista de verificación copiada. Debe estar de acuerdo con el alcance actual, las evaluaciones de riesgos e impacto, el plan de tratamiento, la implementación real, la evidencia y las decisiones sobre riesgos.

9. Cláusula 6.1.4: Evaluación del Impacto del Sistema de IA

La evaluación del impacto de los sistemas de IA examina cómo estos pueden afectar a individuos, grupos y a la sociedad a lo largo de su ciclo de vida.



Impact assessment examines effects on people, groups, and society across the life cycle

Figura 4. Evaluación del impacto de sistemas de IA

9.1 Proceso de evaluación de impacto

- Define los desencadenantes, el alcance, los roles, la independencia, los métodos, la implicación, la aprobación, la retención, la revisión y la relación con el tratamiento y las decisiones de riesgo de las partes.
- Describe el propósito, los usuarios, las personas afectadas, las decisiones/el contenido, el grado de automatización, las alternativas, los datos, el modelo, los proveedores, la geografía, la escala, la duración y los usos prohibidos/previsibles.
- Identificar los beneficios previstos y los impactos adversos en derechos, equidad, privacidad, seguridad, protección, salud, accesibilidad, empleo, finanzas, niños y grupos vulnerables, medio ambiente, cultura, servicios públicos, democracia y condiciones sociales y económicas, según corresponda.
- Considera impactos directos, indirectos, acumulativos, retardados, reversibles/irreversibles, individuales, grupales y sociales.
- Evalúa la probabilidad, la gravedad, la escala, la duración, la reversibilidad, la distribución, la incertidumbre y las opiniones de las partes afectadas.
- Seleccionar mitigaciones, supervisión humana, avisos, decisiones, reparaciones, umbrales y criterios de detención; obtener la aprobación del responsable.
- Actualizar antes de cambios importantes y después de incidentes, quejas, nuevas pruebas, desviaciones o expansiones del uso.

9.2 Evaluación de riesgos frente a evaluación de impacto

Evaluación de riesgos	Evaluación de impacto
Gestiona la incertidumbre que afecta a los objetivos, incluyendo la organización, las personas y la sociedad	Se centra específicamente en los posibles efectos de un sistema de IA en individuos, grupos y sociedad
Puede agregar carteras y procesar riesgos	Debe mantenerse conectado al sistema/uso particular y al contexto afectado
Alimenta el tratamiento, controles y aceptación residual	Alimenta diseño, despliegue, uso, transparencia, supervisión, reparación y supervisión
Ambos deben intercambiar hallazgos y mantenerse coherentes	Ambos requieren métodos documentados, pruebas, decisiones y revisión

10. Cláusulas 6.2 y 6.3: Objetivos y cambios en la planificación

Los objetivos traducen decisiones políticas y de riesgo en resultados medibles; Los cambios deben planificarse y controlarse.

10.1 Récord objetivo

- Objetivo y resultado previsto, política/riesgo/requisito y alcance relacionados.
- Medir, calcular, fuente de datos, población, línea base, objetivo, umbral, frecuencia, propietario, informes y limitaciones.
- Acciones, recursos, responsabilidades, calendario, dependencias, evidencia y método de evaluación.
- Respuesta cuando el rendimiento no alcanza el objetivo; Reevaluación cuando la métrica crea incentivos perjudiciales.

Ejemplo objetivo	Mejor medida
Inventario completo de IA	Sistemas activos con propietario, uso, datos/modelo/proveedor, nivel de riesgo, evaluación y estado validados + sistemas activos reconciliados
Mejorar la puntualidad de las evaluaciones	Días medianos y atrasados desde el cambio de ingreso/material hasta la decisión aprobada de riesgo e impacto por nivel
Fortalecer la evaluación	Sistemas de alto impacto que cumplen con umbrales de aceptación definidos similares a la producción, incluyendo vistas de subgrupos y de fallos graves
Mejorar el control de los proveedores	Proveedores críticos de IA con revisión actual, obligaciones contractuales, evidencia y carencias cerradas + proveedores críticos
Mejorar la remediación	Resultados corregidos y reevaluados mediante eficacia dentro del objetivo basado en el riesgo, con excepción de edad e impacto

10.2 Cambios en la planificación de AIMS

- Define el propósito, las consecuencias, la integridad de los AIMS, los recursos, las responsabilidades, los plazos, la transición, la comunicación, la evidencia y el retroceso.
- Los desencadenantes incluyen alcance, entidad, producto, uso, modelo, datos, proveedor, ley, certificación, proceso, organización, herramientas, método de auditoría y objetivos.

11. Cláusula 7.1: Recursos

La organización debe determinar y proporcionar los recursos necesarios para establecer, operar, evaluar y mejorar los AIMS.

Recurso	Ejemplos	Evidencia
Personas	AIMS, dominio, datos, ML, producto, seguridad, privacidad, legal, seguridad, auditoría, factores humanos	Plan de capacidad, roles, competencia, independencia, carga de trabajo
Datos	Entrenamiento/validación/prueba/producción, etiquetas, metadatos, derechos, conjuntos de referencia	Inventario, linaje, calidad, acceso, retención, procedencia
Herramientas	Desarrollo, anotación, evaluación, monitorización, seguridad, documentación	Inventario aprobado, versiones, validación, acceso, soporte
Cómputo/sistema	Cloud/on-premise/edge, almacenamiento, red, registro, logging y sandbox	Arquitectura, propiedad, capacidad, resiliencia, impacto medioambiental
Finanzas/tiempo	Presupuesto, costes de evaluación, revisión de proveedores, implicación de los interesados, remediación	Planos, aprobaciones, datos reales, restricciones, decisiones

11.1 Decisiones sobre recursos

- Ajusta la profundidad de recursos al alcance, riesgo, complejidad del sistema, escala, obligaciones legales y personas afectadas.
- Desarrollo, validación, aprobación y auditoría separados lo suficiente para gestionar los conflictos de interés.
- Supervisa la sobrecarga de revisores, la cobertura de evaluación, las lagunas de datos, los límites de proveedores, las licencias que expiran, la degeneración de modelos y la deuda técnica.
- Documentar las restricciones aceptadas y su efecto sobre los objetivos y el riesgo residual.

12. Cláusulas 7.2–7.4: Competencia, Conciencia y Comunicación

La competencia, la conciencia y la comunicación hacen que las políticas y los controles sean aplicables a decisiones reales.

12.1 Competencia

- Define la educación, la formación, la habilidad, la experiencia, la independencia, el comportamiento y la autoridad requeridos para el rol y el nivel de riesgo.
- Evaluar la competencia actual; proporcionar formación, mentoría, práctica supervisada, apoyo especializado o reasignación.
- Evalúa la eficacia mediante la observación, la revisión del producto del trabajo, el ejercicio de escenarios, la prueba y los resultados, no solo la asistencia.
- Conservar las pruebas y reevaluarlas tras un cambio en el rol, el sistema, el riesgo, la ley, el método o un incidente.

12.2 Concienciación

- Las personas comprenden las políticas, su contribución, los beneficios de un mejor rendimiento, las consecuencias de la no conformidad, el canal de preocupaciones y la escalada.
- Los usuarios comprenden el uso aprobado y prohibido, las restricciones de datos, la verificación, la supervisión humana, las limitaciones, la gestión de incidentes y quejas, y las condiciones de detención.

12.3 Plan de comunicación

Campo	Pregunta
¿Qué	Política, sistema/uso, límites, impactos, incidentes, resultados, cambios, funciones
Por qué/público	Responsable de la toma de decisiones, trabajador, usuario, persona afectada, cliente, proveedor, regulador, público
Cuando	Puerta del ciclo de vida, intervalo planificado, incidente, queja, cambio, desencadenante legal
Cómo	Formación, aviso, tarjeta del sistema, informe, contrato, panel de control, reunión, alerta
Propietario/aprobación	¿Quién prepara, valida, aprueba, entrega y registra?
Retroalimentación	¿Cómo se gestionan las preguntas, la accesibilidad, la comprensión, las preocupaciones y la corrección?

13. Cláusula 7.5: Información documentada

La información documentada debe estar lo suficientemente controlada como para ser fiable, encontrable, protegida, actualizada, conservada y utilizable.

13.1 Ciclo de vida del control de documentos

- Crear/identificar: título, propietario, ID, versión, fecha, formato, clasificación, alcance, sistema/modelo/datos relacionados y aprobación.
- Revisión/aprobación: revisor competente, conflictos, criterios, comentarios, disposición y autorización.
- Publicar/usar: audiencia correcta, acceso, formación, fecha de vigencia, disponibilidad en el punto de uso y retirada de versiones obsoletas.
- Cambio: motivo, requisitos, procesos y sistemas afectados, aprobaciones, historial de versiones, transición y retroceso.
- Proteger: confidencialidad, integridad, disponibilidad, privacidad, seguridad, copia de seguridad, recuperación y preservación de pruebas.
- Retener/eliminar: periodo legal/comercial, retención, archivo, eliminación, copias de proveedores, datos derivados y verificación.

Registros requeridos/importantes	Ejemplo
Fundación AIMS	Contexto, partes interesadas, alcance, política, mapa de procesos, roles
Planificación	Método/evaluación de riesgos, tratamiento, SoA, proceso/registros de impacto, objetivos, cambios
Operaciones	Inventario, recursos, ciclo de vida, datos, proveedor/uso, comunicación, incidentes
Evaluación	Métricas, análisis, auditoría interna, revisión de gestión
Mejora	No conformidad, corrección, causa raíz, acción correctiva, efectividad
Trazabilidad del sistema	Versiones de modelo/datos/prompt/herramienta/configuración, aprobaciones, evaluaciones, registros, decisiones

14. Cláusula 8.1: Planificación y Control Operativo

La planificación operativa traduce los requisitos de AIMS en controles repetibles para la admisión, el diseño, la adquisición, el despliegue, el uso, el cambio, la gestión de incidentes y la retirada de IA.

14.1 Control operativo

- Definir criterios y controles para los procesos; operarlos conforme a lo previsto; conservar evidencia suficiente para demostrar su desempeño.
- Controlar los cambios planificados y revisar los no deseados; reducir los efectos adversos.
- Controla procesos, productos y servicios proporcionados externamente según su nivel de riesgo y de responsabilidad.
- Utiliza niveles de riesgo y puertas del ciclo de vida para adaptar la revisión, la independencia, las pruebas, la aprobación, la monitorización y la escalada hasta el impacto.

Puerta	Prueba requerida de decisión
Admisión	Propósito, propietario, rol de IA, personas afectadas, datos, proveedor, riesgo preliminar, comprobación de uso prohibido
Diseño/adquisición	Requisitos, riesgo/impacto, arquitectura, recursos, datos, funciones del proveedor, controles, pruebas
Compilar/configurar	Versiones, linaje, desarrollo seguro, documentación, preparación para la evaluación
Validar	Pruebas representativas, umbrales, fallos, desafío independiente, limitaciones, acciones correctivas
Despliegue	Aprobación, condiciones, información de usuario, supervisión, monitorización, incidentes, retroceso, soporte
Operar/cambiar	Rendimiento, deriva, quejas, incidentes, cambios de proveedor, regresión, reevaluación
Jubilación	Reemplazo, comunicación usuario/parte, acceso, integraciones, datos, modelos, registros, eliminación

15. Cláusulas 8.2–8.4: Riesgo Operativo, Tratamiento y Evaluación de Impacto

La organización debe ejecutar evaluaciones de riesgos, tratamientos de riesgos e impactos en intervalos planificados y cuando se produzca un cambio significativo.

15.1 Disparadores operativos

- Sistema de IA nuevo o cambiado, uso previsto, población afectada, geografía, escala, automatización, autoridad de decisión, modelo, datos, prompt, herramienta, integración, proveedor o infraestructura.
- Nueva ley, contrato, incidente, queja, hallazgo de auditoría, vulnerabilidad, inteligencia sobre amenazas, preocupación por la seguridad, deriva, fallo en la evaluación, impacto inesperado o aviso al proveedor.
- Cambios en los criterios de riesgo, objetivos, controles, supervisión, propiedad organizativa, alcance de la certificación o capacidad de los recursos.

15.2 Evidencia operativa

- La evaluación aprobada actual está vinculada a la versión exacta del sistema, modelo, datos, configuración y uso.
- El plan de tratamiento y el SoA coinciden con los controles implementados, las lagunas, las excepciones, la aprobación residual y la monitorización.
- La evaluación de impacto incluye a las partes afectadas, efectos directos/indirectos y sociales, mitigaciones, reparaciones y detonantes de revisión.
- Las acciones se integran en los flujos de trabajo de producto, datos, seguridad, privacidad, proveedores, usuarios, incidentes y cambios.
- Los resultados y cambios se conservan como información documentada controlada.

16. Cláusula 9.1: Monitorización, Medición, Análisis y Evaluación

La evaluación del rendimiento determina si los AIMS y sus controles alcanzan los resultados deseados.

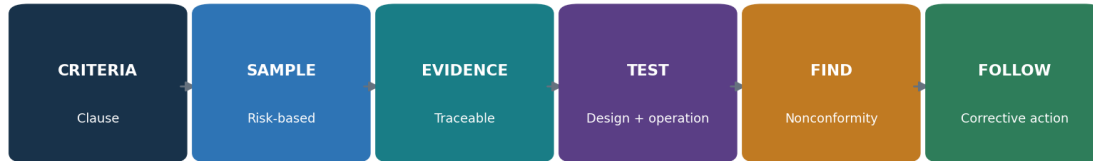
16.1 Diseño de medidas

- Decide qué monitorizar/medir, los métodos, el tiempo, la responsabilidad, los criterios de aceptación, el análisis, la evaluación, los informes y la retención.
- Verifica fuentes de datos, definiciones, poblaciones, integridad, precisión, tiempo, acceso, transformaciones y limitaciones.
- Utiliza indicadores adelantados y rezagados en gobernanza, riesgo, impacto, ciclo de vida, datos, proveedores, uso, quejas, incidentes, auditoría y mejora.
- Evitar promedios que oculten fallos graves o efectos en subgrupos; combinar evidencia cuantitativa y cualitativa.
- Evalúa tendencias y causas, compara con los objetivos y toma decisiones o acciones cuando no se alcanzan los umbrales.

Medida AIMS	Decisión habilitada
Cobertura de inventario/control	Brechas de uso y evaluación de IA desconocidas o no propietarias
Cobertura de riesgo/impacto, edad y cambio	Si las decisiones siguen vigentes tras un cambio de sistema o contexto
Resultados de la evaluación	Liberación, restricción, rediseño, retroceso o supervisión adicional
Quejas/incidentes/repación	Impacto en las personas, recurrencia, comunicación y acciones correctivas
Cambios de proveedores / evidencia	Reevaluación, acción contractual, alternativa o salida
Envejecimiento de auditoría/no conformidad	Control de la debilidad, causa raíz, recursos y atención de la gestión

17. Cláusula 9.2: Auditoría interna

La auditoría interna proporciona evidencia independiente y basada en riesgos de que el AIMS se ajusta y opera de manera eficaz.



AIMS audit conclusions require criteria, evidence, judgment, and follow-up

Figura 5. Cadena de auditoría AIMS

17.1 Programa de auditoría

- Definir objetivos, alcance, frecuencia, métodos, responsabilidades, planificación, criterios, informes, seguimiento, recursos, riesgos y registros.
- Prioriza sistemas de alto impacto, nuevos modelos/uso, controles débiles, incidentes, quejas, cambios, proveedores, hallazgos previos y pruebas obsoletas.
- Seleccionar auditores con competencia, objetividad, confidencialidad, comunicación e independencia en sistemas de gestión e IA.
- Utiliza entrevistas, revisión de documentos, observación, trazado, análisis de datos, muestreo, reinterpretación y demostración técnica de manera segura.
- Informar los resultados a la dirección correspondiente y asegurar la corrección o acción correctiva, así como el seguimiento de la eficacia.

17.2 Documento de trabajo de auditoría

Campo	Ejemplo
Criterios	Cláusula/control exacto, procedimiento interno, ley/contrato según corresponda
Alcance/muestra	Proceso, sistema/versión de IA, periodo, población, justificación de selección
Evidencia	Fuente, propietario, fecha, versión, consulta, observación, fiabilidad
Prueba/resultado	Diseño y funcionamiento, expectativas frente a observados, excepciones
Conclusión	Conformes, oportunidad, observación o no conformidad con base objetiva
Seguimiento	Corrección, causa raíz, acción correctiva, propietario/fecha, efectividad

18. Cláusula 9.3: Revisión de la Dirección

La revisión de gestión garantiza que la alta dirección evalúe la idoneidad, la adecuación, la eficacia, la dirección, los recursos y la mejora.

18.1 Entradas

- Estado de las acciones derivadas de revisiones previas y de cambios en cuestiones internas o externas, o en los requisitos de las partes interesadas.
- Desempeño y tendencias de AIMS: objetivos, inconformidades y acciones correctivas, monitorización y medición, auditorías internas y garantía externa relevante.
- Resultados de evaluaciones de riesgo e impacto, estado del tratamiento, cambios en la SoA, incidentes, quejas, preocupaciones, reparaciones, cambios en proveedores y legales.
- Suficiencia de recursos, competencia, independencia, infraestructuras, datos, herramientas y presupuesto.
- Oportunidades para la mejora continua y la alineación estratégica.

18.2 Salidas

- Decisiones y acciones sobre la mejora, los cambios en el alcance, la política, los objetivos, los procesos y los controles de AIMS, las necesidades de recursos, las decisiones de riesgo y la dirección estratégica.
- Para cada acción: justificación, propietario, fecha límite, recursos, resultado esperado, medida, dependencia, escalada y seguimiento.
- Conserva la agenda, los materiales, los asistentes/autoridades, los debates, las decisiones, la disidencia/preocupaciones, las acciones y las pruebas de cierre.

Evita la revisión en diapositivas: la revisión de la dirección es un proceso de toma de decisiones. Una presentación en un panel sin desafíos, decisiones de riesgo, compromisos de recursos, acciones y seguimiento es evidencia débil.

19. Cláusula 10: No conformidad, acciones correctivas y mejora continua

La mejora corrige problemas, elimina causas, controla la eficacia y fortalece los AIMS a medida que cambian el riesgo y la tecnología.

19.1 Método de acción correctiva

- Reaccionar ante la no conformidad; controlarla/corregirla; abordar las consecuencias, las personas afectadas, las decisiones, los datos, los sistemas y las comunicaciones.
- Evalúa la causa y la recurrencia: revisa la evidencia, determina por qué los controles fallaron o fueron evitados, y encuentra condiciones similares en otros lugares.
- Implementar acciones proporcionales según el propietario, la fecha, los recursos, la protección provisional, el control de cambios y la reevaluación de riesgo/impacto.
- Revisar la efectividad con evidencia definida tras una operación suficiente; no cierras solo por un documento nuevo.
- Actualizar riesgos, impactos, controles, objetivos, competencia, términos de proveedores, monitorización, programa de auditoría e información documentada según sea necesario.
- Conservar la naturaleza de la no conformidad, las acciones y los resultados de efectividad.

Respuesta débil	Respuesta más fuerte
Reentrenar al empleado	Examinar procesos poco claros, carga de trabajo, incentivos, interfaz, acceso, aprobación y monitorización; Causas del sistema de reparación
Política de actualización	Cambiar el flujo de trabajo/control, comunicar, entrenar, probar la operación y monitorizar la recurrencia
El proveedor lo arreglará	Haz seguimiento de contrato, mitigación, control del cliente, fecha límite, prueba, riesgo residual, alternativa/salida
Conclusión cerrada	Corrección de evidencia más revisión de acción y eficacia de la causa raíz en un ámbito similar

20. Anexos A–D y la Declaración de Aplicabilidad

El Anexo A es un conjunto de referencia de 38 controles en nueve grupos; el Anexo B ofrece orientación, el Anexo C proporciona ideas de objetivos/fuentes de riesgo de IA, y el Anexo D apoya el uso por sectores/dominios.

Grupo	Tema	Controles	Enfoque de implementación
A.2	Políticas relacionadas con la IA	3	Políticas, alineación con otras políticas y revisión planificada/basada en eventos.
A.3	Organización interna	2	Roles y responsabilidades en IA, además de un proceso de notificación de preocupaciones protegido.
A.4	Recursos para sistemas de IA	5	Documentar datos, herramientas, sistemas y computación, y recursos humanos a lo largo del ciclo de vida.
A.5	Evaluación de los impactos de los sistemas de IA	4	Un proceso repetible, registros, impactos en personas y grupos, y impactos sociales.
A.6	Ciclo de vida de los sistemas de IA	9	Objetivos y procesos de desarrollo responsable, requisitos, registros de diseño, V&V, despliegue, operación, documentación técnica y registros.
R.7	Datos para sistemas de IA	5	Gestión de datos, adquisición, calidad, procedencia y preparación.
A.8	Información para las partes interesadas	4	Información de usuario, informes externos, comunicación sobre incidentes y otra información de los interesados.
R.9	Uso de sistemas de IA	3	Proceso y objetivos de uso responsable, además de la adhesión al uso previsto.
A.10	Relaciones con terceros y clientes	3	Asignación de responsabilidades, gobernanza de proveedores y obligaciones del cliente.

20.1 Cómo funcionan los anexos

- Las cláusulas 4–10 contienen los requisitos certificables del sistema de gestión.
- El Anexo A proporciona objetivos de referencia y controles a considerar durante el tratamiento de riesgo; no es una lista de verificación universal.
- El Anexo B proporciona orientación de implementación para los controles del Anexo A sin añadir requisitos.
- El Anexo C ofrece ejemplos de objetivos y de fuentes de riesgo de IA que pueden apoyar la planificación y la evaluación.
- El Anexo D explica cómo los AIMS pueden utilizarse en distintos dominios y sectores.
- La organización puede seleccionar controles adicionales; la SoA explica su aplicabilidad e implementación.

21. Anexo A.2: Políticas relacionadas con la IA

El Anexo A.2 establece un marco coherente de políticas de IA que está alineado, aprobado, comunicado y revisado.

21.1 Implementación de control

- Crear una política de IA acorde con los roles, el propósito, el contexto, el riesgo, el impacto y los compromisos de la organización en materia de la responsable.
- Alinearlo con las políticas de seguridad, privacidad, datos, calidad, producto, recursos humanos, adquisiciones, legal, registros, accesibilidad, incidentes y comunicación.
- Resuelve contradicciones como un objetivo de innovación que fomente herramientas no aprobadas o una política de retención que entre en conflicto con la trazabilidad.
- Aprobarla en el nivel de gestión adecuado; comunicarse con las personas y partes relevantes; conectar con los objetivos, procedimientos, controles, formación y aplicación.
- Revisa en el plazo y de acuerdo con la ley, tecnología, negocio, alcance, incidente, auditoría, queja, proveedor o cambio de sistema de materiales.

Evidencia	Test
Política de IA aprobada	Verifica el alcance, compromisos, autoridad, fecha de entrada, disponibilidad y propietario
Mapa de políticas	Rastrear los requisitos de IA hasta políticas relacionadas y conflictos resueltos
Comunicación/formación	Ejemplos de roles; verifica la comprensión y el flujo de trabajo práctico
Historial de críticas	Revisa entradas, cambios, decisiones, aprobación y seguimiento

22. Anexo A.3: Organización interna

El Anexo A.3 asigna responsabilidades a la IA y establece un mecanismo protegido para informar sobre preocupaciones.

22.1 Roles y responsabilidades

- Define la responsabilidad del ciclo de vida y del sistema de gestión para cada sistema de IA y servicio compartido.
- Asignar roles de resultados empresariales, IA/modelo, datos, producto, seguridad, privacidad, legal, impacto, supervisión humana, proveedor, incidente, auditoría y riesgo residual.
- Define la autoridad de aprobación y de escalada, los agentes, los conflictos, la segregación y las decisiones de emergencia.
- Actualizar los roles tras un cambio en la organización, el empleo, el proveedor, el sistema, el alcance o el riesgo; eliminar el acceso de inmediato.

22.2 Preocupaciones sobre la notificación

- Proporcionar canales internos y externos accesibles, confidencialidad y/o anonimato cuando sea apropiado, no represalias, triaje, investigación, protección, escalada, retroalimentación y registros.
- Acepta preocupaciones sobre el uso inseguro, sesgos, derechos, privacidad, seguridad, datos, resultados engañosos, IA oculta, comportamiento de los proveedores, presión para eludir controles o represalias.
- Mide la concienciación, la accesibilidad, la respuesta, la recurrencia, los casos atrasados y las acciones correctivas sin exponer a los denunciantes.

Los canales de preocupación son controles: un canal es ineficaz si las personas no saben que existe, temen represalias, no pueden informar de daños externos o nunca reciben pruebas de que se investigan y se corrigen las preocupaciones.

23. Anexo A.4: Recursos para sistemas de IA

El Anexo A.4 requiere transparencia sobre los datos, herramientas, sistemas/computación y personas necesarios a lo largo del ciclo de vida de la IA.

Registro de recursos	Detalles
Datos	Fuente, propietario, propósito, derechos, sensibilidad, personas, calidad, sesgo, versión, linaje, retención, ubicación
Herramientas	Algoritmos, frameworks, paquetes, modelos, prompts, evaluación, anotación, orquestación, versiones, soporte
Sistema/cómputo	Cloud/on-premise/edge, cuentas, entornos, almacenamiento, red, GPUs, capacidad, resiliencia, energía/entorno
Humano	Rol, organización/proveedor, competencia, independencia, acceso, carga de trabajo, autoridad de decisión
Dependencias	Proveedor, subprocesador, API, identidad, monitorización, filtro de contenido, almacén vectorial, proceso de negocio

23.1 Flujo de trabajo de documentación de recursos

- Conecta recursos con sistemas de IA exactos, etapas del ciclo de vida, propietarios, evaluaciones de riesgo/impacto, registros de proveedores, versiones e historial de cambios.
- Concilia inventarios de recursos con código, registros de modelos, catálogos de datos, facturación en la nube/API, identidad, red, compras y entrevistas.
- Identificar recursos no aprobados/de sombra, componentes no soportados, competencias ausentes, límites de capacidad, dependencias comunes y efectos ambientales.
- Utiliza el registro para la reproducibilidad, la respuesta a incidentes, la evaluación de cambios, la recuperación, la salida de proveedores y la jubilación.

24. Anexo A.5 e ISO/IEC 42005: Evaluación de Impacto del Sistema de IA

El Anexo A.5 operacionaliza la evaluación de impacto; ISO/IEC 42005:2025 proporciona orientación complementaria actual.

24.1 Cuatro resultados de control

- Un proceso definido y repetible para evaluar el impacto de un sistema de IA, con desencadenantes, roles, métodos, integración, aprobación y revisión a lo largo de su ciclo de vida.
- Documentación controlada de evaluaciones, supuestos, evidencias, partes afectadas, impactos, mitigaciones, decisiones y cambios.
- Evaluación específica de los impactos en individuos y grupos, incluyendo equidad, derechos, privacidad, seguridad, salud, accesibilidad, efectos financieros y laborales, personas vulnerables, supervisión humana y reparación, según corresponda.
- Evaluación de efectos sociales más amplios, como la seguridad pública, el medio ambiente, la economía, la cultura, los procesos democráticos, la desinformación, el trabajo, la concentración del mercado y el uso deliberado indebido, según corresponda.

24.2 Controles de calidad de la evaluación

- Las personas o grupos afectados se identifican más allá de los usuarios directos y los clientes.
- Se evalúan tanto los beneficios como los perjuicios, incluyendo la distribución y las alternativas.
- El método considera la escala, la duración, la reversibilidad, los efectos acumulativos e indirectos, la incertidumbre y el uso indebido previsible.
- La implicación de los grupos de interés es significativa, accesible, documentada y protegida.
- Las mitigaciones se convierten en requisitos propios, pruebas, avisos, supervisión, reparación y criterios de detención.
- La versión de evaluación coincide con el sistema/uso desplegado y se actualiza tras un cambio material.

25. Anexo A.6: Ciclo de vida del sistema de IA

El Anexo A.6 conecta los objetivos de desarrollo responsable con los requisitos, el diseño, las pruebas, el despliegue, la operación, la documentación y el registro de eventos.



Responsible-AI objectives become measurable requirements and release evidence

Figura 6. Ciclo de vida responsable de un sistema de IA

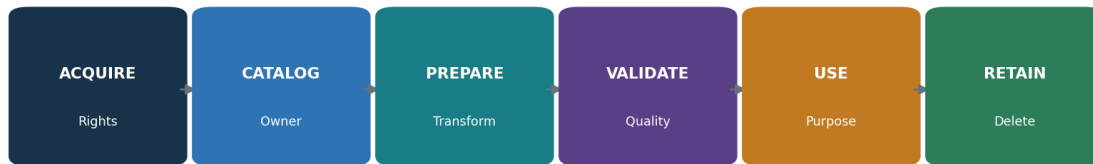
Área del ciclo de vida	Evidencia de implementación
Objetivos/procesos responsables	Equidad, seguridad, privacidad, transparencia, seguridad, robustez y otros objetivos relevantes y medibles; Procedimiento del ciclo de vida
Requisitos/especificaciones	Propósito, criterios funcionales y no funcionales, personas afectadas, datos, modelo, supervisión humana, límites, obligaciones
Registros de diseño/desarrollo	Arquitectura, decisiones, alternativas, suposiciones, componentes, amenazas, interfaces, procedencia, revisiones
Verificación/validación	Métodos, datos de evaluación, puntuadores, umbrales, fallos graves, pruebas de subgrupo/borde/adversariales, limitaciones
Despliegue	Aprobación de liberación, entorno, configuración, información de usuario, migración, monitorización, retroceso
Operación/monitorización	Rendimiento, deriva, seguridad, protección, impacto, quejas, cambios, soporte, reparación, actualizaciones
Documentación/registros técnicos	Instrucciones apropiadas para el público y eventos rastreables para auditorías, incidentes, decisiones y mejoras

25.1 Cambio y jubilación

- Modelo de versiones, datos, prompts, recuperación, herramientas, código, infraestructura, políticas, evaluación, aprobaciones y monitorización.
- Definir los desencadenantes del cambio de material y del alcance de la regresión; desplegar gradualmente con retroceso.
- Retirar usuarios, identidades, integraciones, endpoints, modelos, conjuntos de datos, índices, registros, documentación, contratos y copias de proveedores conforme a las obligaciones; conservar los registros requeridos.

26. Anexo A.7: Datos para sistemas de IA

El Anexo A.7 exige la adquisición de datos, la calidad, la procedencia y la preparación reguladas para el desarrollo, la mejora y la operación de la IA.



Data evidence must preserve source, transformations, quality, authority, and lifecycle

Figura 7. Cadena de evidencia de datos de IA

26.1 Controles de datos

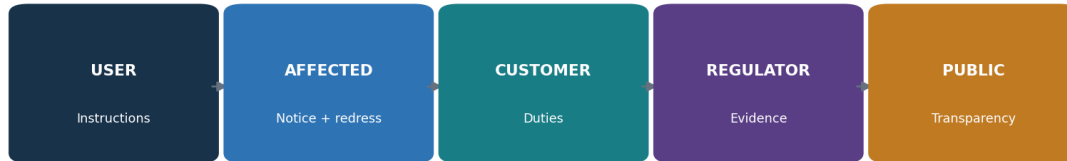
- Definir los requisitos de gestión de datos para privacidad, seguridad, representatividad, explicabilidad, procedencia, precisión, integridad, disponibilidad, retención y eliminación según corresponda.
- Adquisición/selección de documentos: fuente, método, personas/población, derechos/licencia, propósito previo, consentimiento/autoridad cuando corresponda, metadatos, fecha, restricciones y sesgo conocido.
- Establezca criterios de calidad y umbrales específicos para la precisión, la completitud, la consistencia, la actualidad, la unicidad, la validez, la representatividad, las etiquetas y la cobertura de los subgrupos.
- Preservar la procedencia mediante la creación, adquisición, transferencia, transformación, etiquetado, aumentación, filtrado, versión, validación, uso, compartición, corrección y eliminación.
- Métodos de preparación de documentos, código/herramienta/versión, parámetros, personas, controles de calidad, justificación, resultados y reproducibilidad.
- Separar y proteger los conjuntos de datos de entrenamiento, validación, prueba, producción, monitorización e incidentes; evitar fugas de datos en el conjunto de evaluación.

Evidencia de datos	Test
Conjunto de datos/tarjeta de datos	Trazar propósito, población, campos, origen, derechos, calidad, limitaciones, propietario
Linaje	Reproduce transformaciones de fuente a característica y versión
Resultado de calidad	Verificar la población completa/muestra, normas, fallos, corrección y aprobación
Acceso/retención	Subvenciones de ejemplo, reseñas, eliminaciones, uso, copias, eliminación

Evidencia de datos	Test
Sesgo/representación	Revisa los grupos relevantes, historial, proxies, etiquetas, lagunas y mitigación

27. Anexo A.8: Información para las Partes Interesadas

El Anexo A.8 requiere información útil para los usuarios y las partes interesadas, además de informes y comunicación sobre incidentes.



Different interested parties need different useful and timely information

Figura 8. Información de las partes interesadas

Paquete informativo 27.1

- Usuarios: propósito previsto, capacidades, limitaciones, entradas/salidas esperadas, uso prohibido, verificación, supervisión humana, monitorización, escalada y soporte.
- Personas afectadas: que se utilice la IA cuando sea apropiado, papel en la decisión, factores y limitaciones importantes, datos y derechos, revisión humana, corrección, apelación, queja y reparación.
- Clientes/socios: responsabilidades, configuración, datos, dependencias de control, evidencia, incidentes, cambios, soporte y salida.
- Reguladores/auditores: documentación controlada, alcance, evaluaciones, controles, resultados de las pruebas, incidentes, cambios, hallazgos y acciones correctivas, según corresponda.
- Público: transparencia proporcional, impactos significativos, gobernanza, información de seguridad, contactos e informes cuando sea apropiado.

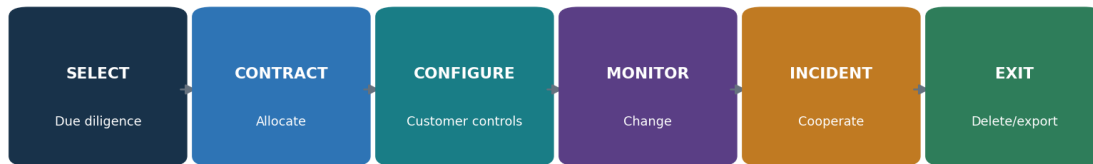
27.2 Informes y incidentes externos

- Proporcionar canales accesibles para informar sobre errores, daños, sesgos, preocupaciones de seguridad y privacidad, mal uso, problemas de accesibilidad o efectos inesperados.
- Define triaje, gravedad, investigación, protección, retroalimentación, corrección, reparación, escalada, retención y análisis de tendencias.
- Predefinir las audiencias del incidente, el contenido, el propietario/portavoz, la revisión legal, el momento, la canalización, la accesibilidad, la coordinación, las actualizaciones y el cierre.

- No revelar en exceso información sensible a la seguridad o a la personal; no ocultar limitaciones materiales bajo la confidencialidad.

28. Anexos A.9 y A.10: Uso responsable, proveedores y clientes

El Anexo A.9 regula el uso responsable y el propósito previsto; el Anexo A.10 asigna responsabilidades entre proveedores, clientes y la cadena de valor de la IA.



Third-party AI risk persists from selection through verified exit

Figura 9. Ciclo de vida de IA de terceros

28.1 Uso responsable

- Definir usos, usuarios, datos, salidas, decisiones, autonomía, verificación, supervisión humana, registro, soporte, incidente y condiciones de detención aprobadas y prohibidas.
- Establece objetivos medibles de uso responsable vinculados a los impactos y riesgos relevantes.
- Formar a usuarios y supervisores; hacer cumplir la ley mediante la identidad, la configuración, las interfaces, las políticas, la monitorización, la revisión y las consecuencias.
- Detectar la ampliación de alcance y requerir una reevaluación antes de reutilizar, expandir, incorporar nuevas poblaciones, aumentar el impacto o integrar nuevas herramientas.

28.2 Terceros y clientes

- Desarrolladores/proveedores/desplegadores de mapas, proveedores de datos/modelos/herramientas/nube, integradores, servicios humanos, clientes, usuarios y partes afectadas.
- Asignar la responsabilidad de los datos, requisitos, pruebas, configuración, transparencia, supervisión humana, seguridad, incidentes, monitorización, cambio, derechos, eliminación y salida.
- Realizar diligencia debida basada en riesgos y contratación; verificar la documentación del modelo/sistema, evaluación, seguridad/privacidad, términos de datos, IP, soporte, vulnerabilidades, cambios, subprocesadores, resiliencia y portabilidad.
- Monitoriza el modelo, los términos, la formación, la retención, los subprocesadores, los incidentes y los cambios de secuencia, y reevalúa con rapidez.

- Definir las obligaciones y el soporte al cliente; no utilices la responsabilidad del cliente como una transferencia vaga de las responsabilidades del proveedor.

29. Certificación, ISO/IEC 42006:2025, y Preparación para la Auditoría

La certificación evalúa los AIMS según ISO/IEC 42001 dentro de un alcance definido; ISO/IEC 42006:2025 refuerza los requisitos para los organismos certificadores.

29.1 Camino de certificación

- Seleccione un organismo de certificación competente y verifique su acreditación/estatus, esquema, geografía, competencia, imparcialidad, alcance y contrato.
- Aplicación y planificación: organización, alcance de AIES, roles, sitios, personas, sistemas, complejidad, procesos externalizados, estándares y tiempo de auditoría.
- Etapa 1: preparación, alcance, sistema documentado, contexto, métodos de riesgo/impacto, SoA, auditoría interna, revisión de gestión y preparación para la Fase 2.
- Etapa 2: implementación y efectividad operativa mediante entrevistas, muestras, registros, observación y seguimiento directo.
- Resolver las inconformidades con corrección, causa, acción correctiva y evidencia de efectividad, conforme a las normas del esquema.
- Decisión de certificación, certificado, vigilancia, cambios de alcance, recertificación, suspensión/retirada y mejora continua.

29.2 Importancia de ISO/IEC 42006:2025

- Añade requisitos específicos de AIMS para organismos que auditan y certifican conforme a ISO/IEC 42001 y se basa en ISO/IEC 17021-1.
- Apoya la competencia adecuada, los procesos de auditoría consistentes, la imparcialidad, el tiempo de auditoría y el rigor para las organizaciones que desarrollan, proporcionan o utilizan sistemas de IA.
- La organización debe verificar que la certificación reclamada se emita conforme a un esquema de acreditación relevante y que el alcance y el estatus del certificado coincidan con la reclamación.

Paquete de pruebas de auditoría	Ejemplos
Fundación	Alcance, contexto, partes, política, mapa de procesos, roles, inventario
Planificación	Método de riesgo/resultados, tratamiento, SoA, proceso/resultados de impacto, objetivos, cambios
Apoyo/operación	Recursos, competencia, comunicación, documentos, ciclo de vida, datos, uso, proveedores, incidentes
Evaluación/mejora	Métricas, auditoría interna, revisión de la dirección, hallazgos, acciones correctivas, eficacia
Muestras traza	Registros de extremo a extremo para sistemas de IA representativos de alto riesgo, medio/bajo y cambios materiales

29.3 Preparación para auditoría sin teatro

- Operar los controles el tiempo suficiente para producir pruebas honestas; No crees registros después de los hechos.
- Reconciliar alcance, inventario, riesgo, impacto, SoA, proveedores, versiones del sistema, métricas, auditoría y revisión de la gestión.

- Entrena a los entrevistados para que expliquen su trabajo real y muestren pruebas, no memoricen respuestas.
- Divulga con precisión las lagunas, los riesgos aceptados, las limitaciones, los incidentes y las acciones correctivas.

30. Herramientas de Evidencia de Código Abierto de AIMS y Garantía de IA

Las herramientas de código abierto pueden soportar trazabilidad, evaluación, monitorización, políticas, privacidad y hallazgos, pero no deciden la conformidad con la ISO.

Herramienta	Propósito
MLflow	Seguimiento de experimentos, registro de modelos, linaje, aprobación y registros de despliegue
DVC	Control de versiones para datos, modelos y pipelines
OpenLineage	Estándar abierto y herramientas para eventos de datos/línea de trabajo
OpenMetadata	Catálogo de datos, linaje, propiedad, glosario y metadatos de calidad
Grandes Expectativas	Expectativas automatizadas de calidad de datos y resultados de validación
Evidentemente	Calidad de los datos, deriva, rendimiento del modelo e informes de monitorización
Deepchecks	Pruebas para datos, modelos de aprendizaje automático y aplicaciones de LLM
Giskard	Pruebas de IA y escaneo de vulnerabilidades
Promptfoo	Evaluaciones rápidas, modelo, RAG y red-team
Garak	Escaneo de vulnerabilidades y sondas de LLM
PyRIT	Identificación de riesgos y orquestación de equipos rojos para IA generativa
Inspect AI	Evaluaciones de IA reproducible
Presidio	Detección y desidentificación de información personal
ModelScan	Escaneo estático de archivos de modelos serializados
CycloneDX	Formatos y herramientas de listas de materiales para software, ML e IA
Agente de Políticas Abiertas	Decisiones de política como código
DefectDojo	Encontrar ingresos, deduplicación, propiedad, remediación y reanálisis
Langfuse	Rastreo de LLM de código abierto, gestión de prompts y evaluación

Gobernanza de herramientas: Utiliza únicamente sistemas autorizados, modelos, cuentas, repositorios y datos. Empieza con entornos aislados y datos sintéticos. Protege credenciales, indicaciones, salidas, rastreos, información personal y hallazgos. Anota las versiones y valida los resultados automáticos.

30,1 MLflow

Propósito: Seguimiento de experimentos, registro de modelos, linaje, aprobación y registros de despliegue. Proyecto oficial: [MLflow](#)

Inicio rápido y seguro: Crea un proyecto local; establece parámetros de registro, referencia de conjuntos de datos, métricas, artefactos, propietario y aprobación; registra solo un modelo probado; restringe los cambios en el registro.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.2 DVC

Propósito: Control de versiones de datos, modelos y pipelines. Proyecto oficial: [DVC](#)

Inicio rápido y seguro: Utiliza un conjunto de datos sintético en un repositorio de entrenamiento; gestiona las versiones de los datos y las etapas de la canalización; reproduce una carrera; protege el almacenamiento remoto y las credenciales.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.3 OpenLineage

Propósito: Estándar abierto y herramientas para eventos de datos/línea de trabajo. Proyecto oficial: [OpenLineage](#)

Inicio rápido y seguro: instrumentar una pequeña tubería de laboratorio; registrar conjuntos de datos y relaciones laborales; comprobar la integridad del evento; proteger los metadatos sensibles.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.4 OpenMetadata

Propósito: Catálogo de datos, linaje, propiedad, glosario y metadatos de calidad. Proyecto oficial: [OpenMetadata](#)

Inicio rápido y seguro: desplegar una instancia de laboratorio; catálogo de conjuntos de datos sintéticos; asignar propietarios y clasificar; documentar la línea y la retención; restringir los conectores.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.5 Grandes Esperanzas

Propósito: Automatizar las expectativas de calidad de los datos y de los resultados de validación. Proyecto oficial: [Grandes Esperanzas](#)

Inicio rápido y seguro: Definir precisión, completitud, alcance y expectativas nulas para los datos sintéticos; ejecutar la validación; preservar la suite, la versión, los resultados y las excepciones.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.6 Evidentemente

Propósito: calidad de los datos, deriva, rendimiento del modelo e informes de monitorización. Proyecto oficial: [Evidently](#)

Inicio rápido y seguro: crear conjuntos de datos sintéticos de referencia y actuales; elaborar un informe; definir umbrales de acción; investigar antes de reentrenarlo o revertirlo.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.7 Deepchecks

Propósito: Pruebas de datos, modelos de aprendizaje automático y aplicaciones de LLM. Proyecto oficial: [Deepchecks](#)

Inicio rápido y seguro: ejecutar una suite especializada en datos de laboratorio aprobados; revisar la relevancia y los falsos positivos; registrar las excepciones; reemisión tras la corrección.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30,8 Giskard

Propósito: pruebas de IA y análisis de vulnerabilidades. Proyecto oficial: [Giskard](#)

Inicio rápido seguro: Conecta solo un modelo de prueba y un conjunto de datos aprobados; selecciona pruebas relevantes; valida fallos manualmente; guarda el informe y la revisión de remediación.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.9 Promptfoo

Propósito: Evaluaciones de prompts, modelos, RAG y red team. Proyecto oficial: [Promptfoo](#)

Inicio rápido y seguro: crear una suite YAML versionada con casos sintéticos y comportamientos esperados; gestionarla localmente; gestionar los fallos en las revisiones; conservar la configuración y los resultados.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.10 Garak

Propósito: Escaneo de vulnerabilidades y de sondas de LLM. Proyecto oficial: [Garak](#)

Inicio rápido seguro: Utiliza un modelo de laboratorio aislado y un conjunto limitado de sondas aprobado; peticiones y costes de tope salarial; proteger las salidas; validar cada hallazgo.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.11 PyRIT

Propósito: Identificación de riesgos y orquestación de equipos rojos para IA generativa. Proyecto oficial: [PyRIT](#)

Inicio rápido y seguro: definir las reglas escritas del laboratorio; utilizar objetivos inofensivos y datos sintéticos; establecer límites de solicitudes, de tiempo y de costes; proteger las transcripciones y los hallazgos.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.12 Inspeccionar IA

Propósito: Evaluaciones de IA reproducibles. Proyecto oficial: [Inspect AI](#)

Inicio rápido y seguro: Define una tarea, un conjunto de datos, un solucionador, un puntuador y una regla de aceptación; versiones con pin; ejecutar un modelo aprobado; conserva registros y limitaciones.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.13 Presidio

Propósito: Detección y desidentificación de información personal. Proyecto oficial: [Presidio](#)

Inicio rápido y seguro: probar en ejemplos sintéticos; configurar reconocedores de lenguaje y contexto; inspeccionar falsos positivos y fallos; proteger la salida del analizador.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.14 ModelScan

Propósito: Escaneo estático de archivos de modelos serializados. Proyecto oficial: [ModelScan](#)

Inicio rápido seguro: escanear un artefacto en cuarentena; verificar la fuente y el hash; investigar advertencias; nunca cargar un modelo no confiable solo para probarlo.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.15 CycloneDX

Propósito: Formatos y herramientas de software, ML e IA para listas de materias. Proyecto oficial: [CycloneDX](#)

Inicio rápido seguro: Generar una lista de materiales para un repositorio de laboratorio; validar componentes y versiones; vincular los hallazgos con los registros de propietarios y proveedores.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.16 Agente de Políticas Abiertas

Propósito: Decisiones de política como código. Proyecto oficial: [Agente de Políticas Abiertas](#)

Inicio rápido y seguro: Redacta una pequeña norma de laboratorio para el modelo/datos/usuarios aprobados; pruebas para permitir casos, denegar y datos perdidos; cambios en la revisión por pares; mantener la autoridad de la excepción humana.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprobación.

30.17 DefectDojo

Propósito: Encontrar la admisión, deduplicación, propiedad, remediación y reprobación. Proyecto oficial: [DefectDojo](#)

Inicio rápido seguro: Importar resultados de laboratorio seguros; validar duplicados y gravedad; asignar propietario/fecha; adjuntar pruebas; Cerrar solo después de volver a probar.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprueba.

30.18 Langfuse

Propósito: Rastreo de LLM de código abierto, gestión de prompts y evaluación. Proyecto oficial: [Langfuse](#)

Inicio rápido seguro: Utiliza un laboratorio aprobado; redactar campos sensibles; trazar un flujo de trabajo; restringir el acceso/retención; Conecta las trazas con los registros de evaluación y incidentes.

Evidencia de AIMS: autoridad/alcance, sistema/modelo/versiones de datos, identidad, herramienta/versión/configuración, criterios/umbrales, fecha, población fuente, resultado, validación humana, limitaciones, hallazgo, propietario/acción, aprobación y reprueba.

31. Manual de jefe y analista junior, laboratorio y entrevistas

Los directivos mantienen los AIMS ligados a resultados reales; los analistas júniores crean inventarios fiables, documentos de trabajo, hallazgos y evidencia de mejora.



Junior analysts demonstrate competence through practical, traceable AIMS work

Figura 10. Vía para analista junior de AIMS

31.1 Preguntas sobre el gerente

Pregunta	Pruebas sólidas	Bandera roja
¿Qué incluye el alcance?	Límites de inventario de IA conciliado, organización/rol/sistema/datos/proveedores	Ámbito de marketing más amplio que el certificado
¿Quién puede decidir?	Autoridad designada para negocios, sistemas, datos, impacto, riesgo, proveedores, incidentes y auditorías	El equipo de IA asume solo el riesgo empresarial y legal
¿Qué daños son posibles?	Evaluaciones actuales de riesgos e impacto con personas afectadas y alternativas	Solo se considera la precisión del modelo
¿Qué prueba la preparación?	Evaluación versionada similar a la producción, umbrales, fallos, supervisión, retroceso	Solo demo o política del proveedor
¿Qué cambia el riesgo?	Lista de desencadenantes, monitorización, aviso al proveedor, regresión, reevaluación	Actualizaciones automáticas sin revisión
¿Está mejorando el AIMS?	Objetivos, auditoría, quejas/incidentes, causas raíz, acciones efectivas	El certificado es la única medida de éxito

31.2 Trabajo como analista junior

- Mantener el inventario, el alcance, las partes interesadas, las obligaciones, los registros de riesgo/impacto, el SoA, los registros de proveedores, los objetivos, las pruebas y las acciones.
- Asignar cláusulas y controles a procesos y a la evidencia real del sistema; reconciliar poblaciones y versiones.
- Prueba de control de documentos, competencia, puertas del ciclo de vida, línea de datos/calidad de datos, evaluación, uso responsable, cambio de proveedor, monitorización, incidentes y acciones correctivas.

- Redactar hallazgos objetivos y resúmenes de directivos; realizar el seguimiento de la corrección y de la prueba de efectividad.
- Apoyar auditorías internas y revisiones de gestión, sin tomar decisiones reservadas a los propietarios o a los auditores.

Regla de laboratorio de portafolio: Utiliza una organización ficticia, datos sintéticos y modelos de prueba locales o aprobados. Nunca afirmes que el proyecto está certificado, auditado por un organismo acreditado o basado en pruebas confidenciales del empleador.

31.3 Laboratorio ficticio

- Crea una empresa ficticia de 100 personas que desarrolla un asistente RAG para la atención al cliente y utiliza un asistente de redacción de RRHH adquirido que no puede tomar decisiones laborales.
- Define el contexto de AIMS, las partes interesadas, los roles, el alcance, la política, el mapa de procesos, el inventario de IA, las obligaciones y la hoja de ruta de implementación.
- Crear un método de riesgo, seis escenarios de riesgo, un plan de tratamiento, un SoA con 38 controles y dos evaluaciones de impacto, utilizando los conceptos de la ISO/IEC 42005.
- Construir registros de recursos, conjuntos de datos, modelos/sistemas, proveedores, información de usuario, comunicación, competencia y control documental.
- Realizar evaluaciones sintéticas usando dos herramientas de código abierto; conservar versiones, umbrales, fallos y correcciones, y volver a probar.
- Crear objetivos/panel de control, un plan de auditoría interna y cinco documentos de trabajo, dos conclusiones, acciones correctivas, paquete de revisión de gestión e informe de preparación para la certificación.
- Publica solo pruebas ficticias suavizadas y una declaración honesta de limitaciones.

31.4 Plan de treinta días

Días	Enfoque	Entrega
1–3	Estándar, AIMS, PDCA	Mapa de cláusulas y glosario
4–6	Contexto, partes, alcance	Ámbito y registro de partes interesadas
7–9	Liderazgo y planificación	Política, RACI, objetivos
10–12	Riesgo y tratamiento	Método, registro, plano, SoA
13–15	Evaluación de impacto	Dos documentos de trabajo de impacto
16–18	Soporte y documentos	Competencia, comunicación, control documental
19–21	Ciclo de vida, datos, uso, proveedores	Cinco documentos de control
22–24	Medición y herramientas	Panel de control y evidencia de evaluación
25–27	Auditoría y acciones correctivas	Informe de auditoría, conclusiones, plan de eficacia
28–30	Revisión de la dirección y entrevista	Paquete de reseña, memorándum de preparación, historias de STAR

31.5 ¿Qué es ISO/IEC 42001?

Un estándar certificado para sistemas de gestión para organizaciones que desarrollan, proporcionan o utilizan sistemas de IA. Establece requisitos para una gobernanza responsable, riesgo, impacto, operación, evaluación y mejora.

31.6 ¿Qué es un AIMS?

Las políticas, objetivos, procesos, roles, controles y registros interrelacionados de la organización para gestionar la IA de forma responsable dentro de un alcance definido.

31.7 ¿Son obligatorios todos los controles del Anexo A?

Son controles de referencia considerados mediante el tratamiento de riesgo. La organización documenta la aplicabilidad e implementación en la Declaración de Aplicabilidad y puede añadir otros controles.

31.8 ¿Evaluación de riesgo frente a impacto?

La evaluación de riesgos gestiona la incertidumbre que incide en los objetivos. La evaluación del impacto de los sistemas de IA se centra en los efectos sobre los individuos, los grupos y la sociedad. Intercambian hallazgos, pero no son idénticos.

31.9 ¿Qué es la Declaración de Aplicabilidad?

Un registro controlado que explique qué Anexo A y controles adicionales se aplican, por qué, cómo se implementan, su estado, las evidencias, las lagunas y la revisión.

¿31.10 Fase 1 frente a Fase 2?

La Etapa 1 evalúa el alcance, el sistema documentado, la preparación y la planificación. La Etapa 2 evalúa la eficacia de la implementación y la operación mediante evidencia y muestreo.

31.11 ¿Qué es una no conformidad?

No se cumple un requisito. El hallazgo debe identificar criterios, evidencia objetiva y la carencia, sin prescribir la solución al auditado.

31.12 ¿Cómo demuestran las herramientas la conformidad?

No es así. Las herramientas producen pruebas que deben definirse, validarse, interpretarse según los requisitos, conectarse a controles y revisarse por personas competentes.

31.13 ¿Cómo se prueba una acción correctiva?

Verificar la corrección, la acción de la causa raíz, la aplicación a condiciones similares y la evidencia de que el riesgo de recurrencia se redujo tras una operación suficiente.

31.14 ¿Qué hace a un analista junior fuerte?

Alcance preciso, evidencia cuidadosa, comprensión de las cláusulas, redacción clara, respeto hacia las personas afectadas, incertidumbre honesta, uso seguro de herramientas y seguimiento fiable.

32. Plantillas, glosario, índice y referencias oficiales

Las estructuras de trabajo reutilizables y las referencias autorizadas apoyan la implementación y auditoría consistentes de AIMS.

32.1 Registro de alcance y contexto de AIMS

Campo	Entrada
Organizaciones/unidades de negocio/ubicaciones	_____
Rol en IA, productos/servicios/procesos	_____
Sistemas/modelos/datos/entornos de IA	_____
Problemas internos/externos	_____
Partes interesadas y requisitos	_____
Obligaciones legales/contractuales	_____
Fronteras, interfaces, dependencias	_____
Procesos externalizados/compartidos	_____
Exclusiones y justificación	_____
Disparadores de aprobación y revisión del alcance	_____

32.2 Historial de riesgo y tratamiento de IA

Campo	Entrada
Sistema/uso/versión/propietario	_____
Escenario, parte afectada, consecuencia	_____
Probabilidad/impacto/incertidumbre/evidencia	_____
Controles existentes y efectividad	_____
Evaluación/tolerancia de riesgos	_____
Opción de tratamiento/control	_____
Anexo A/mapeo adicional de control	_____
Propietario/recurso/fecha/medida	_____
Riesgo/aprobación/condiciones residuales	_____
Monitorización/revisión/reexamen	_____

32.3 Declaración de Aplicabilidad

Campo	Entrada
Referencia/título de control	_____
Aplicabilidad y justificación	_____
Riesgo/impacto/obligación relacionados	_____
Implementación y propietario	_____
Estado y fecha objetivo	_____
Pruebas y resultados de la prueba	_____
Dependencias de proveedores/clientes	_____
Riesgo de brecha/excepción/residual	_____
Última y siguiente reseña	_____
Historial de cambios/aprobación	_____

32.4 Evaluación del impacto en sistemas de IA

Campo	Entrada
Propósito, uso, personas afectadas, alternativas	_____
Sistema/datos/modelo/proveedor/contexto	_____
Beneficios e impactos adversos	_____

Campo	Entrada
Efectos individuales/grupales/sociales	_____
Probabilidad/gravedad/escala/duración	_____
Reversibilidad/distribución/incertidumbre	_____
Participación de las partes interesadas	_____
Mitigación/supervisión/transparencia/reparación	_____
Decisión/autoridad/condiciones	_____
Monitorización/desencadenantes/revisión	_____

32.5 Documento de trabajo de auditoría interna

Campo	Entrada
Criterios/alcance/objetivo	_____
Proceso/sistema/versión/periodo	_____
Población/muestra/justificación	_____
Evidencia/fuente/fiabilidad	_____
Prueba o resultado esperado	_____
Resultado/excepciones observadas	_____
Conclusión/no conformidad	_____
Indicación de riesgo/impacto/causa	_____
Corrección/acción correctiva	_____
Eficacia/seguimiento/cierre	_____

32.6 Historial de revisión de la dirección

Campo	Entrada
Estado de acción previa	_____
Contexto/cambios de partido	_____
Objetivos/tendencias de rendimiento	_____
Riesgo/impacto/tratamiento/SoA	_____
Auditoría/inconformidad/acciones correctivas	_____
Incidentes/quejas/preocupaciones/reparación	_____
Cambios en proveedores/legales/sistema	_____
Recursos/competencia	_____
Decisiones/acciones/propietarios/fechas	_____
Eficacia/seguimiento	_____

32.7 Glosario

Término	Significado
OBJETIVOS	Sistema de gestión de inteligencia artificial.
Evaluación del impacto de sistemas de IA	Evaluación estructurada de los posibles efectos sobre individuos, grupos y sociedad.
Anexo A	Objetivos y controles de referencia ISO/IEC 42001.
Anexo B	Guía de implementación para los controles del Anexo A.
Certificación	Atestación de terceros de que el AIMS con alcance cumple con los requisitos especificados.
Conformidad	Cumplimiento de un requisito.
Control	Medidas que mantienen o modifiquen el riesgo.
Corrección	Acción para eliminar un no conformidad detectada.
Acciones correctivas	Acción para eliminar la causa y prevenir la recurrencia.
Información documentada	La información que la organización controla y mantiene, además de su medio.
Parte interesada	Persona u organización que puede afectar, ser afectada por o percibir que se ve afectada por una decisión o actividad.
Auditoría interna	Proceso sistemático independiente y objetivo para evaluar la evidencia frente a los criterios.
No conformidad	No cumplir un requisito.
Objetivo	Resultado por lograr.

Término	Significado
Riesgo residual	Riesgo que permanece tras el tratamiento.
Propietario de riesgo	Persona/entidad con responsabilidad y autoridad para gestionar riesgos.
SoA	Declaración de Aplicabilidad.
Etapa 1	Fase de preparación para la certificación y auditoría del sistema documentado.
Etapa 2	Fase de implementación de certificación y auditoría de eficacia operativa.
Alta dirección	Persona/grupo que dirige y controla la organización al más alto nivel dentro del alcance.

32.8 Índice temático

Tema	Capítulo
Controles del Anexo A	20–28
Auditoría	17, 29
Certificación	29
Contexto/alcance	3–4
Acciones correctivas	19
Datos	23, 26
Documentos	13
Evaluación de impacto	9, 24
Partes interesadas	4, 27
Liderazgo/política	5, 21
Ciclo de vida	14–15, 25
Manager/analista junior	31
Medición/revisión	16–18
Objetivos/cambio	10
Recursos/competencia	11–12, 23
Riesgo/tratamiento/SoA	6–8
Proveedores/uso	28
Herramientas	30

32.9 Referencias oficiales

- [Página oficial ISO/IEC 42001:2023](#)
- [Explicación de la ISO 42001](#)
- [Plataforma de navegación en línea ISO/IEC 42001](#)
- [ISO/IEC 42005:2025 Evaluación del impacto del sistema de IA](#)
- [Organismos de certificación ISO/IEC 42006:2025](#)
- [Directrices de auditoría ISO 19011:2026](#)
- [ISO/IEC 23894:2023 Gestión del riesgo de IA](#)
- [ISO/IEC 22989:2022 Conceptos y terminología de IA](#)
- [Marco del sistema ISO/IEC 23053:2022](#)
- [ISO/IEC 38507:2022 implicaciones de gobernanza de la IA](#)
- [Catálogo ISO/IEC JTC 1/SC 42](#)
- [Normas ISO para sistemas de gestión](#)
- [IAF CertSearch](#)
- [Marco de Gestión de Riesgos de IA del NIST](#)
- [Principios de IA de la OCDE](#)
- [Página oficial de política de la Ley de IA de la UE](#)

Recordatorio final: Utiliza una copia autorizada del estándar. Las normas ISO, los esquemas de certificación, la acreditación, las leyes, los sistemas de IA, los proveedores, los riesgos, las herramientas y las directrices oficiales cambian. Verifica la fuente actual, la edición exacta, el alcance/estado del certificado, la versión del sistema y los datos organizativos antes de la implementación, auditoría, certificación o reclamaciones públicas.